

January 2026 CSE 406: Cyber Security Sessional

Online 2: Ethical Hacking

Section: A1

Time: 40 minutes

Ethical-use warning

This is an intentionally vulnerable, isolated teaching environment. Use the techniques in this assignment only against the supplied local containers. Never test an application, account, or network without explicit authorization. The same actions against a real service may be unethical and illegal.

Objective

You have access to two campus applications: the **Library Fines Portal** and the **Campus Marketplace**. Acting as the designated attacker account, fully compromise the pair as follows:

Discover the structure of the Library Fines database and extract every member's total outstanding fine. A member may have several fine records, some already paid, and members with no unpaid fines must still appear with a zero total. Then persist a browser payload through the same vulnerable input so that checking your own fine balance automatically publishes a Marketplace listing. The listing title must be exactly `I owe $<total> in fines`, and its price must be the same `<total>`. The amount must be derived from the current database records by the exploit rather than hard-coded into the final payload.

Environment Setup

The Moodle archive contains `A1-images.tar`, `compose.yaml`, and this specification. Internet access is not required after download. From the directory containing those files, run:

```
seed@ubuntu:~$  
  
docker load --input A1-images.tar  
docker compose up -d  
docker compose ps
```

Wait until all three services are running. Open:

- Library Fines Portal: `http://localhost:4000`
- Campus Marketplace: `http://localhost:4001`

To reset every database change, session, and listing and return to the original seeded state:

```
seed@ubuntu:~$  
  
docker compose down  
docker compose up -d
```

The 40-minute limit includes image loading and environment startup. Raise your hand immediately if Docker reports an infrastructure error before either page opens.

Credentials

Role	Member ID	Fines PIN	Marketplace user	Marketplace password
Attacker	4100001	rahman-41	anika.rahman	market-Anika-41
Victim	4100002	karim-41	farhan.karim	market-Farhan-41

Tasks and Marks

The core assignment is worth 10 marks. One bonus mark is available.

1. **SQL injection confirmation (1 mark):** Demonstrate that the PIN input can change the meaning of the Library Fines query.
2. **Schema discovery (2 marks):** Enumerate the relevant application tables and columns, identify the relationship between members and individual fine records, and identify how paid and unpaid records are represented.
3. **Complete aggregate extraction (3 marks):** Extract every member's ID, name, and total unpaid amount through the vulnerable portal. Correctly aggregate multiple records and include zero-total members.
4. **Persistent browser payload (1 mark):** Use a stacked statement through the PIN input to persist a stored-XSS payload in the attacker's own member record.
5. **End-to-end compromise (3 marks):** With the attacker logged in to the Marketplace, a normal check of the attacker's fine balance must create the exact required listing and numeric price without a separate post action. The final amount must be calculated from the database by the exploit.
6. **Bonus - cover your tracks (+1):** Discover the forensic trail left by portal submissions and, through the same injection channel, delete only the trail attributable to member 4100001. Evidence belonging to every other member must remain intact.

Restrictions

- All injection, extraction, persistent modification, and cleanup used for grading must be issued through the Library Fines Portal while the Member ID field contains **4100001**. Direct database edits do not earn marks.
- The victim credentials are supplied only for optional session testing. Logging in as another member to read their displayed total is not extraction.
- Do not attack anything outside the supplied local environment.
- Do not disrupt another student's workstation or containers.

Submission

Create a plain-text file named with your seven-digit student ID, for example `2105XXX.txt`. For every graded stage, include:

1. the exact value or payload submitted;
2. the application, field, and account where it was submitted;
3. the observed result and all extracted member totals; and
4. the ordered steps needed to reproduce the final Marketplace listing.

Submit only this text file through Moodle. Payloads without their input location or without enough context to reproduce the attack may not receive credit.